

WEB SERVICE WITH JWT AUTHENTICATION AND AUTHORIZATION

INTRODUCTION

A Web service is a software system that supports interoperable machine - to - machine interaction over a network. It has an interface described in a machine processable format(specifically, web Service Definition Language, or WSDL). Web services fulfill a specific task or a set of tasks. A web service is described using a standard , formal XML notion , called its service description, that provides all of the details necessary to interact with the service, including message formats(that detail the operations),transport protocols and location.

JSON Web Token is an open standard(RFC 7519) that defines a compact and self-contained way for securely transmitting information between parties as a JSON object. This information can be verified and trusted because it is digitally signed. In its compact form, JSON Web Tokens consists of three parts separated by dots(.), which are:

- Header
- Payload
- Signature

OBJECTIVE

To design a web service with JWT authentication and authorization and test it using Postman.

REQUIREMENTS

1. PyCharm IDE

Modules used:

- i. Flask-
It is a web framework for Python, allowing us to build web applications. It provide the core functionality for building web applications. It is used to define routes, handle HTTP requests , and return JSON responses.
- ii. jwt-
JWT is a compact, URL-safe means of representing claims to be transferred between two parties. It used for authentication and authorization in web applications. It is used to encode and decode JWTs.
- iii. Json-
In Python it is used for encoding and decoding JSON data. It is used to load user data from a JSON file and save it back after a new user is registered.
- iv. Blueprint class-
The Blueprint class is used to create modular components in a Flask application. It helps in structuring by grouping related routes and functionality together.
- v. 'request' Object (from Flask)-
The 'request' object is provided by Flask and allows us to access data submitted in an HTTP request.

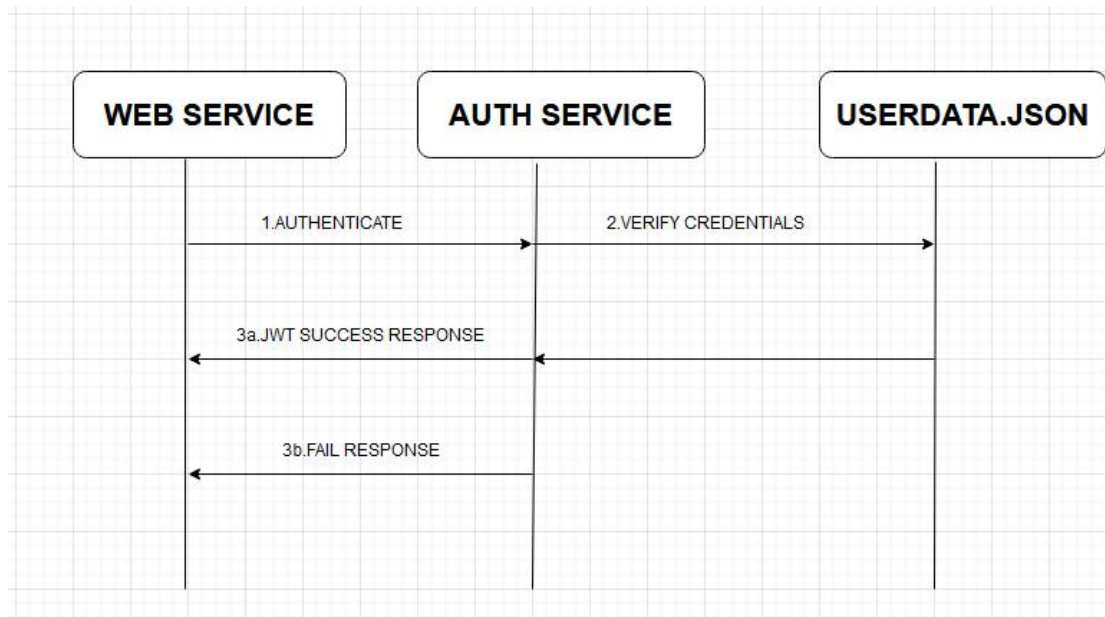
vi. 'jsonify' Function(from Flask)-

The 'jsonify' function is used to convert Python dictionaries into JSON-formatted responses. It simplifies the process of returning JSON responses from Flask routes.

2. Postman

3. Terminal/Command Prompt

ARCHITECTURE



IMPLEMENTATION

Below is the implementation of authentication and authorization that generates JSON Web Tokens.

- First we create authController.py that represents a simple authentication system using Flask, which follows a modular architecture.

Break down of the architecture:

1. Flask Application and Blueprint-

The code defines a Flask Blueprint named 'auth_app'. Blueprints are used to organize a set of related routes and functionality in a modular way.

The 'app' Blueprint encapsulates authentication-related routes such as user registration ('/signup'), user login('/signin'), and a test page that requires authentication ('/testPage')

2. User Data Storage-

User data is stored in a JSON file named 'userData.json'. This file is read and loaded into memory when the Flask application starts.

3. User Registration('/signup' Route)-

Handles HTTP POST requests for user registration.

Validates that both a username and password are provided in the JSON payload. Checks if the provided username already exists in the loaded user data.

If Validation passes,a new user is added to the in-memory user data, and the data is saved back to 'userData.json'.

Returns a JSON response indicating successful user registration or an error response if validation fails.

4. User Login('/signin' Route)-

Handles HTTP POST requests for user login.

Validates that both a username and password are provided in the JSON payload

Checks if the provided credentials match any user in the loaded user data.

If valid, generates a token for the authenticated user using the 'generated_token' function

Returns a JSON response indicating successful login with the generated token or an error response if validation fails.

5. TestPage('/testPage' Route)-

Handles HTTP GET requests for a test page that requires authentication.

Extracts the token from the request headers.

Checks if the token is provided.If not, returns an error response indicating a missing token.

Attempts to verify the token using the 'verify_token' function.

If successful, returns a JSON response indicating successful access to the page along with the username.If verification fails,returns an error response.

6. Token Generation and Verification-

The code references two functions, 'generate_token' and 'verify_token', for token generation and verification, respectively.Token generation typically involves creating a JWT, and verification involves checking the validity of a JWT.

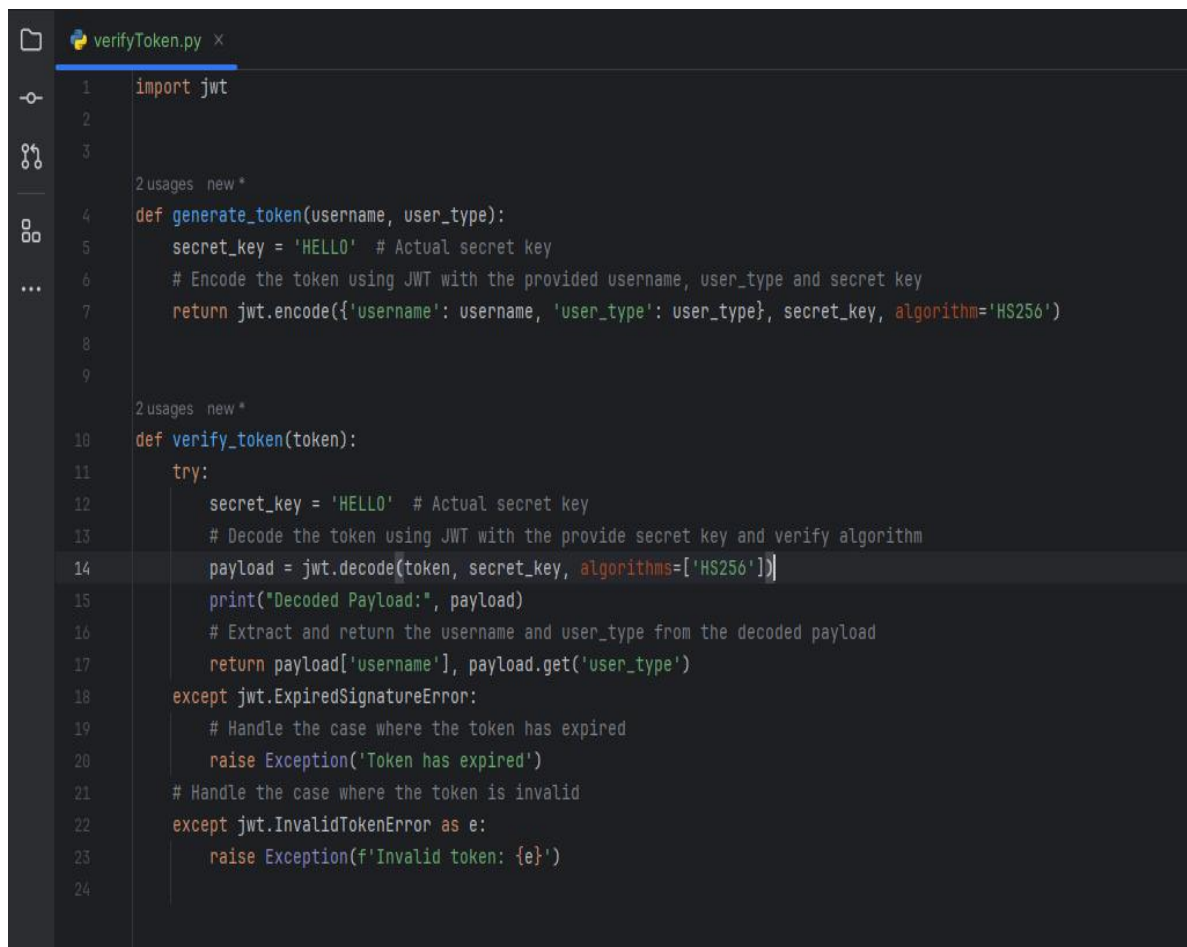
```
authController.py x
1 from flask import Blueprint, request, jsonify
2 from verifyToken import generate_token, verify_token
3 import json
4
5 # Creating a Blueprint instance for the authentication-related routes
6 app = Blueprint(name='auth_app', __name__)
7
8 # Loading user data from userData.json
9 with open('userData.json', 'r') as json_file:
10     users = json.load(json_file)
11
12
13 # Route for user registration
14 new *
15 @app.route(rule='/signup', methods=['POST'])
16 def signup():
17     # Extract user registration data from the request
18     data = request.get_json()
19     username = data.get('username')
20     password = data.get('password')
21
22     # Check if both username and password are provided
23     if not username or not password:
24         return jsonify({'message': 'Username and password are required'}), 400
25
26     # Check if the username already exists
27     if any(user['username'] == username for user in users):
28         return jsonify({'message': 'Username already exists'}), 400
29
30     # Add the new user to the userData.json file
31     new_user = {'username': username, 'password': password}
32     users.append(new_user)
33
34     with open('userData.json', 'w') as file:
35         json.dump(users, file, indent=2)
36
37     return jsonify({'message': 'User registered successfully'}), 201
38
```

```
authController.py
40 @app.route(rule='/signin', methods=['POST'])
41 def signin():
42     # Extract user login data from the request
43     data = request.get_json()
44     username = data.get('username')
45     userType = "true"
46     password = data.get('password')
47
48     # Check if both username and password are provided
49     if not username or not password:
50         return jsonify({'message': 'Username and password are required'}), 400
51
52     # Check if the provided credentials are valid
53     user = next((user for user in users if user['username'] == username and user['password'] == password), None)
54
55     if user:
56         # Generate a token for the authenticated user
57         token = generate_token(username, userType)
58         return jsonify({'message': 'Login successful', 'token': token})
59     else:
60         return jsonify({'message': 'Invalid credentials'}), 401
61
62
63 # Route for a test page that requires authentication
64 new *
65 @app.route(rule='/testPage', methods=['GET'])
66 def test_page():
67     # Extract the token from the request headers
68     token = request.headers.get('token')
69
70     # zcheck if the token is provided
71     if not token:
72         return jsonify({'message': 'Token is missing'}), 401
73
74     try:
75         # Verify the token and extract the username
76         username = verify_token(token)
77         return jsonify({'message': 'Page accessed', 'username': username})
78     except Exception as e:
79         return jsonify({'message': str(e)}), 401
```

- Second, we create the verifyToken.py that defines two functions related to JWT(JSON Web Token) processing: ‘generate_token’ and ‘verify_token’.
- 1. ‘generate_token’ Function-
Generates a JWT token based on the provided ‘username’ and ‘user_type’.
The function takes ‘username’ and ‘user_type’ as parameters.
A secret key (‘HELLO’) is used to sign the token
The ‘jwt.encode’ function from the ‘jwt’ library is used to encode the payload (containing username and user_type) into a token using the specified secret key and algorithm(‘HS256’)
The encode token is returned.
- 2. ‘verify_token’ Function-
The function takes a ‘token’ as a parameter.
A secret key(‘HELLO’) is used to verify the token’s signature.
The ‘jwt.decode’ function from the ‘jwt’ library is used to decode the token, extracting the payload and checking the signature’s validity.
The decoded payload is printed for demonstration purposes.
The ‘jwt.ExpiredSignatureError’ exception is caught to handle the case where the token has expired.

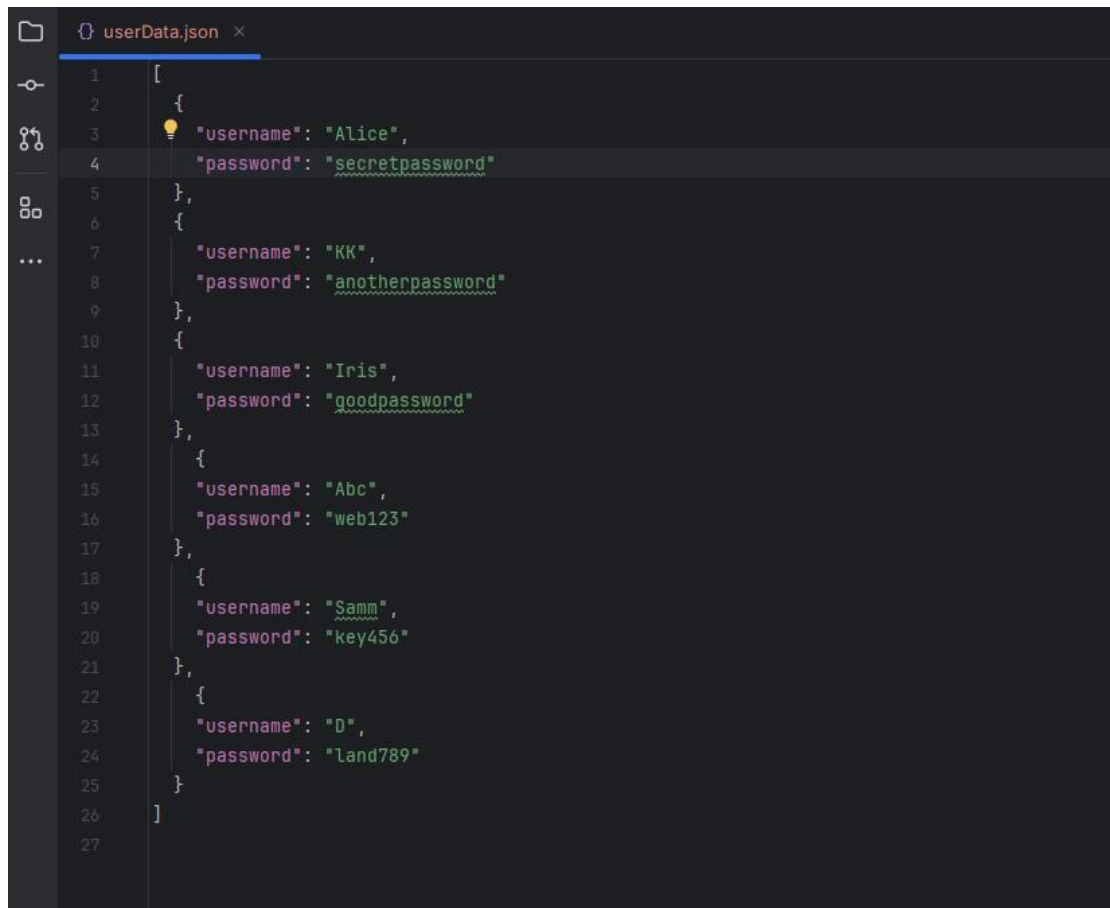
The 'jwt.InvalidTokenError' exception is caught to handle other invalid token scenarios.

If the verification is successful, the 'username' and 'user_type' are extracted from the payload and returned.



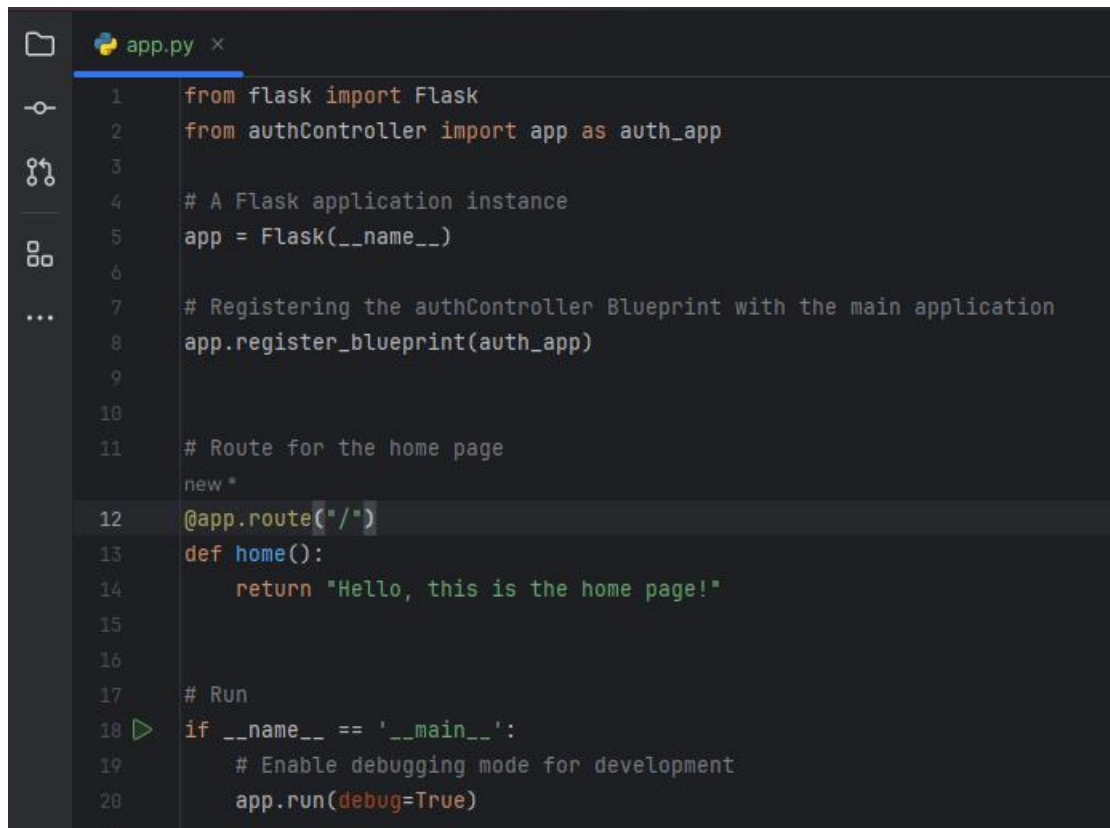
```
verifyToken.py x
1 import jwt
2
3
4 def generate_token(username, user_type):
5     secret_key = 'HELLO' # Actual secret key
6     # Encode the token using JWT with the provided username, user_type and secret key
7     return jwt.encode({'username': username, 'user_type': user_type}, secret_key, algorithm='HS256')
8
9
10 def verify_token(token):
11     try:
12         secret_key = 'HELLO' # Actual secret key
13         # Decode the token using JWT with the provide secret key and verify algorithm
14         payload = jwt.decode(token, secret_key, algorithms=['HS256'])
15         print("Decoded Payload:", payload)
16         # Extract and return the username and user_type from the decoded payload
17         return payload['username'], payload.get('user_type')
18     except jwt.ExpiredSignatureError:
19         # Handle the case where the token has expired
20         raise Exception('Token has expired')
21     # Handle the case where the token is invalid
22     except jwt.InvalidTokenError as e:
23         raise Exception(f'Invalid token: {e}')
24
```

- Third, we provide JSON data to represent a list of user credentials, specifically usernames and passwords
The data structure is a list of dictionaries, where each dictionary represents a user with a username-password pair. Each user has a unique combination of username and a password.



```
1  [
2    {
3      "username": "Alice",
4      "password": "secretpassword"
5    },
6    {
7      "username": "KK",
8      "password": "anotherpassword"
9    },
10   {
11     "username": "Iris",
12     "password": "goodpassword"
13   },
14   {
15     "username": "Abc",
16     "password": "web123"
17   },
18   {
19     "username": "Samm",
20     "password": "key456"
21   },
22   {
23     "username": "D",
24     "password": "land789"
25   }
26 ]
27
```

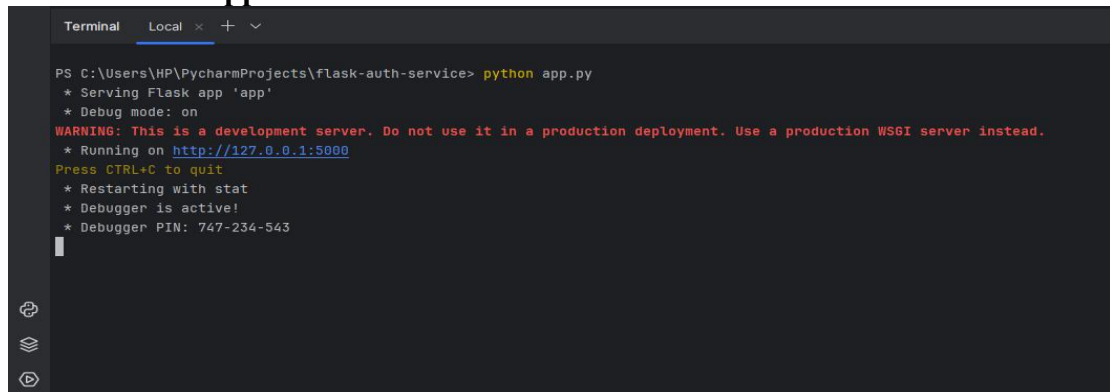
- Last, we create the main entry point for a Flask application.
- 1. Flask Application Instance-
We create a Flask application instance named 'app'
- 2. Blueprint Registration-
Registers the 'authController' Blueprint with the main application.
'auth_app' is a Blueprint instance defined in the 'authController' module.\
- 3. Development Server Run-
The code includes a block that runs the application when the script is executed directly. This block is wrapped with 'if __name__ == '__main__':'.



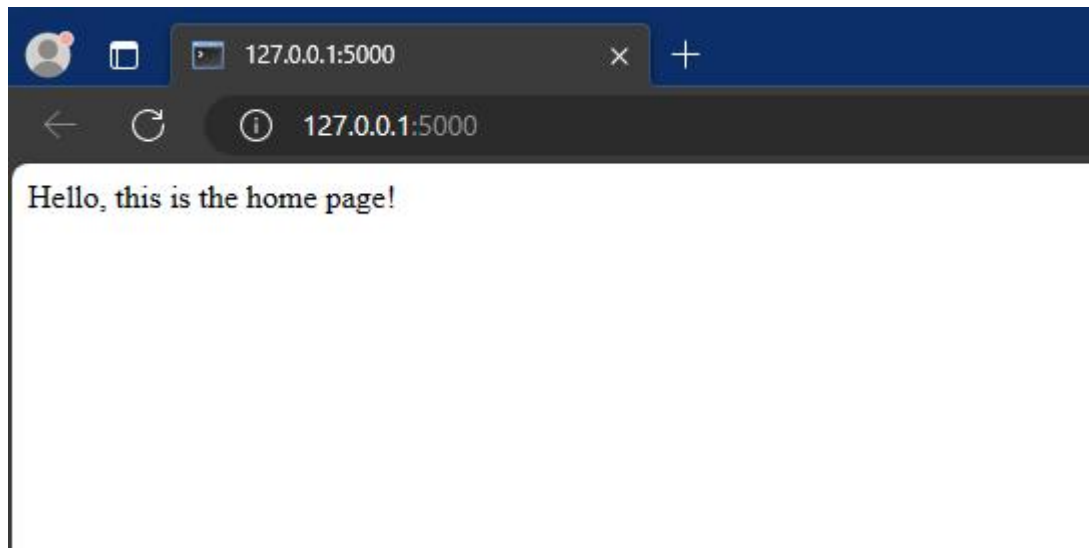
```
1 from flask import Flask
2 from authController import app as auth_app
3
4 # A Flask application instance
5 app = Flask(__name__)
6
7 # Registering the authController Blueprint with the main application
8 app.register_blueprint(auth_app)
9
10
11 # Route for the home page
12 new *
13 @app.route("/")
14 def home():
15     return "Hello, this is the home page!"
16
17 # Run
18 if __name__ == '__main__':
19     # Enable debugging mode for development
20     app.run(debug=True)
```

TESTING

Run the Flask application-

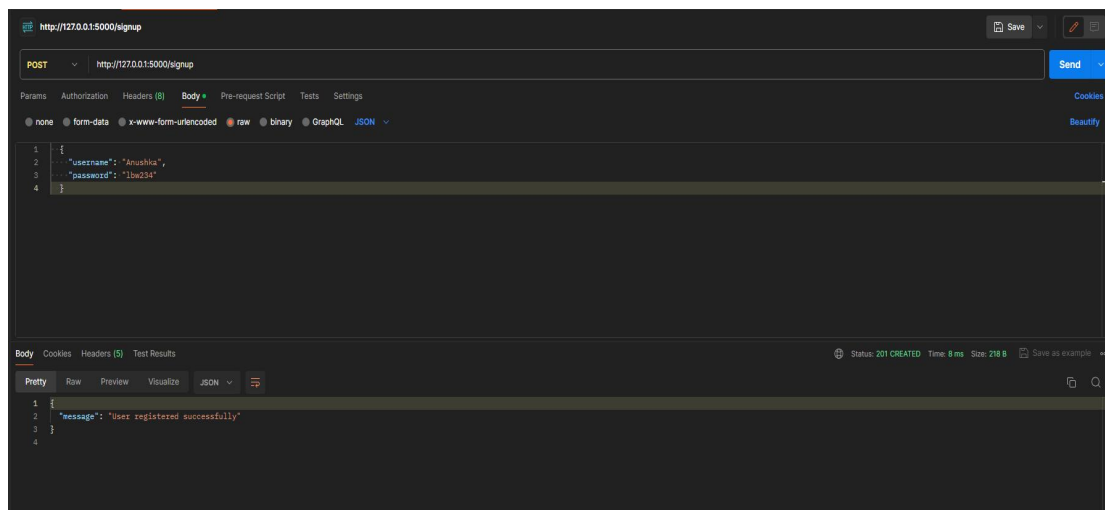


```
Terminal Local x + v
PS C:\Users\HP\PycharmProjects\flask-auth-service> python app.py
* Serving Flask app 'app'
* Debug mode: on
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
* Running on http://127.0.0.1:5000
Press CTRL+C to quit
* Restarting with stat
* Debugger is active!
* Debugger PIN: 747-234-543
```

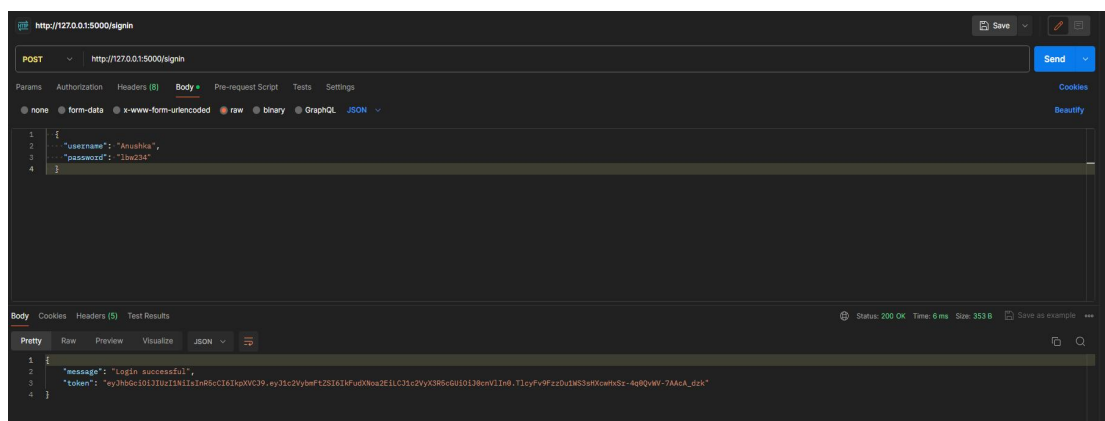



Open Postman

1. Route for signup



2. Route for signin



3. Route for Test Page

